LLM-OWASP-MCP-AUTONOMY

OWASP LLM2025·프롬프트 주입·MCP·자율성 통제

연관 기출 · 138-1-12, 136-2-3, 136-4-5, 137-2-3, 140-2-6, 133-3-2

한눈에 이해

모델이 읽은 외부 문장을 명령으로 오해하더라도 실제 도구가 권한 밖의 일을 못 하도록 시스템에 서 경계를 둡니다.

정의와 핵심 원리

LLM보안은모델·데이터·검색·프롬프트·출력·도구·실행 권한을 포함하는 응용전체 보안입니다. 프롬프트인젝션은신뢰하지 않는입력이 모델의 의도된정책·작업을 변경하도록유도하는취약점이며 직접 입력과 검색 문서등간접경로를 구분합니다.

• OWASP2025의10항목은 프롬프트주입, 민감정보 노출, 공급망, 데이터/모델 오염, 부적절출력 처리, 과도한에이전시, 시스템프롬프트누출, 벡터/임베딩취약점, 허위정보, 무제한소비입니다. 이전판번호와 섞지말고발생지점·영향·대응을 연결합니다.

• MCP는 모델과 도구·자원을 연결하는프로토콜이 지만도구 설명·응답의 신뢰, OAuth동의, 대상 audience·토큰 검증, confused deputy, token passthrough, SSRF, 로컬서버 실행이 공격면입니다. 서버허용목록·서명/검토·최소scope·리소스별인가·비밀격리·감사를적용합니다.

• 고성능AI의사이버 공격 지원은 피싱·정찰·코드생성·자동화 규모를 늘릴수 있어접근·오용탐지·위험능력 평가가 필요합니다. 자율성위험은 목표오해·권한과 다·연쇄행동·예산폭주로설명하고 읽기/쓰기 분리·허용도구·고위험 행위 승인·격리·지출/시간한도·중단/복구를 설계합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
모델수준	정렬·강건성평가	정책이 탈가능성잔존
응용수준	출력 검증·권한·실행격리	비밀·SQL·도구 경계
운영수준	감시·승인·중단·복구	자율성·규모·사고 대응

적용 예제

검색 문서의 악성 지시

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 문서본문에비밀을외부로 보내라는문장포함

1. 문서를 데이터로 취급하고 명령권한을 주지않습니다.
2. 모델 출력과 무관하게도구 서버가 사용자·리소스 권한을 검증합니다.
3. 외부 전송·삭제·배포같은 중요작업은 구체대상과 내용을 검토합니다.
4. 실행 로그·예산·중단조건과 사고회수를 갖춥니다.

결과·해석: 필터한겹보다신뢰 경계와 최소 권한으로 실제 피해를제한합니다.

전제·주의: 프롬프트필터·정렬만 으로주입완전차단을 보장하지 않습니다.MCP는 열람시2026-07-28보안 문서에 근거합니다.

답안 골격과 혼동 방지

LLM전체 구조 → 2025Top10 → MCP공격·대응 → 공격 지원·자율성 → 권한 경계예

- 시스템프롬프트를절대비밀저장소로쓰지않습니다.
- 모델이 안전하다고응답한것을인가판정으로쓰지않습니다.

내용을 가리고 회상

1. 간접주입은어디서들어옵니까?
2. MCP토큰 전달을 무조건 허용하면 왜위험합니까?
3. 자율성한도와사람 승인은 어떤행위에 필요합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- 2025 Top10 Risk and Mitigations for LLMs and GenAI Apps - OWASP GenAI Security Project; 2025 목록; 확인 2026-11-05.
- MCP Security Best Practices - Model Context Protocol project; 2026-07-28 경로; 확인 2026-11-05.
- NIST AI100-2e2025: Adversarial Machine Learning - Apostol Vassilev et al. / NIST; 2025-03; 확인 2026-11-05.